Progettazione e Validazione di Tecniche per Generazione di File Casuali Verosimili per Data Flooding against Ransomware

RELATORE
Prof. Saverio Giallorenzo

CORRELATORE
Dott. Simone Melloni

LAUREANDO
Massimiliano Fioravanti

Il Ransomware e la Difesa tramite Data Flooding

→ **Ransomware**

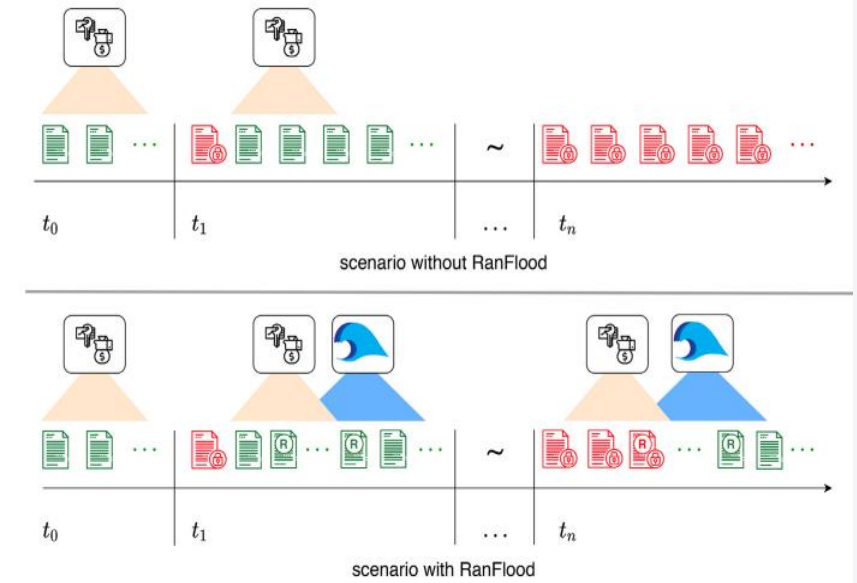
Malware che cifra i file dell'utente per richiedere un riscatto.

→ **Data Flooding**

Inondazione strategica del file system con migliaia di file esca.

→ **Obiettivo della Difesa**

Ostacolare il ransomware inducendolo a cifrare anche file esca.



Il Limite dei File Casuali e la Necessità di Verosimiglianza

Problema

- Contenuto puramente casuale.
- **Entropia elevata** e pattern anomali.
- Facilmente individuabili dalle euristiche dei ransomware.

Soluzione

- Generazione di file **statisticamente verosimili**.
- Tecnica generale che rispetta le strutture dei file reali (in questo lavoro ci si concentra sui formati PDF, TXT, DOCX, JPG).

L'obiettivo non è la validità semantica, ma la compatibilità statistica.

Rappresentazione Statistica

→ **BYTE FREQUENCY DISTRIBUTION**

Distribuzione delle frequenze dei 256 valori di byte.

→ **N-gram**

Catturano le dipendenze tra byte consecutivi.

→ **Estrazione Strutturale**

Analisi di header e metadati, evitando sezioni compresse.

- **PDF**: Header (64KB) + Trailer (8KB), rimossi gli stream binari;
- **JPG:** Header fino al marker SOS + marcatori FFxx;
- **DOCX**: File XML dall'archivio ZIP, ignorate immagini ed embedding;
- **TXT**: Intero contenuto, nessuna estrazione necessaria.

Metriche di Analisi Statistica

Per quantificare la similarità statistica tra file, si adottano metriche di distanza e similarità tra distribuzioni di byte.

→ **Entropia di Shannon**

Grado di casualità della distribuzione dei byte di un file.

→ **Jensen-Shannon Divergence**

Divergenza tra le distribuzioni di byte di due file.

→ **Cosine Similarity**

Similarità tra le distribuzioni di byte di due file.

→ **Total Variation Distance**

Differenza complessiva tra le distribuzioni di byte di due file.

Costruzione del Detector

→ **Dataset Reali e Random**

Raccolta di campioni rappresentativi per PDF, JPG, DOCX e TXT, composto da 10.000 file reali e 2.000 file casuali per PDF, JPG e TXT, e da 5.000 file reali e 2.000 file casuali per DOCX.

→ **Firma Media (N-gram)**

Calcolo del profilo statistico medio del dataset reale tramite bigrammi.

→ **Definizione Soglie**

Creazione di una funzione obiettivo ottimizzata tramite **Dual Annealing**.

→ **Cross-validation**

Validazione su 3 fold per ridurre il rischio di overfitting.

Valutazione del Detector

→ **Obiettivo della Prova**

Verificare la capacità del detector di distinguere file reali da file puramente casuali.

→ **Risultato Complessivo**

Accuratezza superiore al 98% per tutti i formati, con errori minimi concentrati su TXT e JPG.

→ **Validazione su dataset esteso**

Su 109.000 file JPG reali il 97.5% è stato classificato
correttamente; Su 78.000 file TXT reali il 99.32%.

FORMATO	FN	FP
JPG	150 (1.50%)	11 (0.59%)
DOCX	2 (0.04%)	0 (0.00%)
PDF	3 (0.03%)	0 (0.00%)
TXT	161 (1.61%)	1 (0.01%)

Generazione tramite Modello Markoviano

→ **Modello a Catena di Markov**

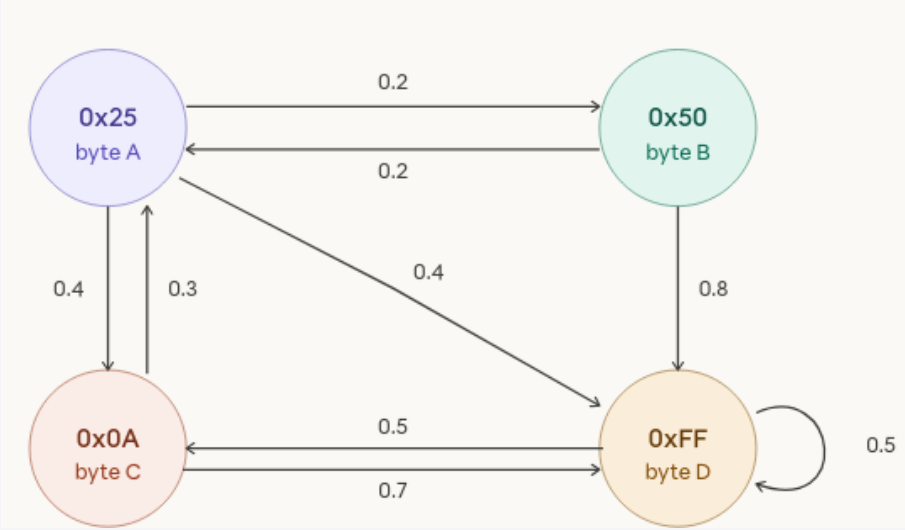
Generazione sequenziale in cui ogni byte dipende esclusivamente dal precedente.

→ **Matrice di Transizione P**

Contiene le probabilità del byte successivo dato quello corrente, stimate dai file reali.

→ **Efficienza: Alias Method**

Tecnica di campionamento che garantisce una generazione in tempo costante O(1) per byte.



Valutazione dei File Generati tramite Detector

→ **Obiettivo della Prova**

Verificare se i file generati "ingannano" il nostro detector.

→ **Metodologia di Test**

Classificazione di 100.000 file sintetici tramite le soglie di verosimiglianza definite.

→ **File classificati come verosimili: 96,80%**

La maggior parte dei file generati viene classificata come verosimile dal detector.

Validazione Esterna tramite Google Magika

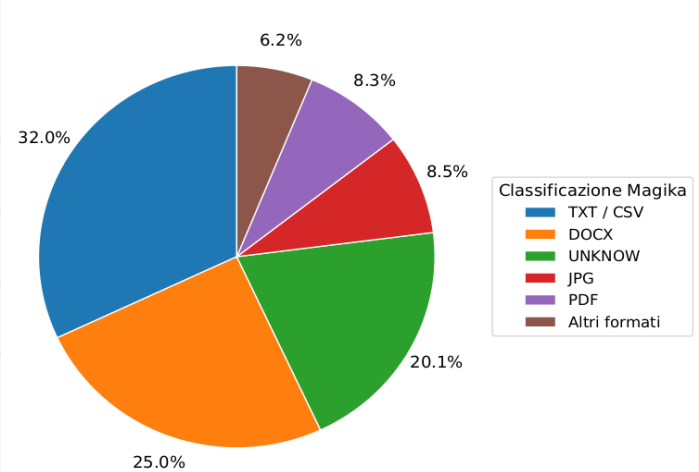
→ **Validazione Indipendente**

Utilizzo di Google Magika per identificare il formato basandosi sul contenuto binario.

→ **Test**

Sono stati generati 100.000 file, 25.000 per formato. La maggior parte dei file viene riconosciuta correttamente da Magika, confermando la coerenza statistica.

Formato



Conclusioni e Sviluppi Futuri

→ Obiettivo Raggiunto

Generazione di file esca **statisticamente verosimili.**
Circa il 97% dei file generati viene classificato come verosimile dal detector.
Validazione tramite **Google Magika**, che riconosce correttamente i formati nella maggior parte dei casi, pur presentando alcuni errori di classificazione.

→ Costo Computazionale

- Costo in memoria delle matrici di transizione per formato: $\boldsymbol{O}(\mathbf{256^2})$.
- Generazione e scrittura su disco di un file di lunghezza L: $\boldsymbol{O}(\boldsymbol{L})$.
- Costo totale per la generazione di N file di lunghezza L: $\boldsymbol{O}(\boldsymbol{N} \cdot \boldsymbol{L})$.

→ Sviluppi Futuri

Test contro euristiche di ransomware reali.
Uso di catene di Markov di ordine superiore.

GRAZIE PER L'ATTENZIONE

Appendice: Formule Matematiche

FUNZIONE OBIETTIVO (SOGLIE)

$$C(T) = \alpha \cdot FN(T) + \beta \cdot FP(T)$$

SCELTA PROSSIMO BYTE (MARKOV)

$$\mathbb{P}(X_{n+1} = j \mid X_n = i) = P_{ij}$$

ENTROPIA DI SHANNON

$$H = -\sum_{i=0}^{255} p(i) \log_2 p(i)$$

JENSEN-SHANNON (JSD)

$$\mathrm{JSD}(P, Q) = \frac{1}{2}\mathrm{KL}(P|M) + \frac{1}{2}\mathrm{KL}(Q|M)$$

COSINE SIMILARITY

$$\cos(X, Y) = \frac{\sum_{i=0}^{255} X_i Y_i}{\sqrt{\sum_{i=0}^{255} X_i^2}, \sqrt{sum_{i=0}^{255} Y_i^2}}$$

TOTAL VARIATION (TVD)

$$\mathrm{TVD}(P, Q) = \frac{1}{2}\sum_{i=0}^{255} |P_i - Q_i|$$